

Atbalsts platformas kiberdrošības stāvoklis

Stāvoklis 2026 gada 10 septembrī

Galvenais secinājums Platforma ir gatava skaidri marķētai prezentācijas videi. PR 73 ir apvienots pēc sekmīgas CI pārbaudes, publiski darbojas precīzs main komits 664b5e5, sensitīvā diagnostika ir slēgta, bet atgriešanās un abu procesu automātiska atjaunošanās ir praktiski pārbaudīta. Tas vēl nav pilnas produkcijas gatavības vai juridiskas atbilstības apliecinājums.

Prezentācijas gatavība

93%

Pilnas produkcijas drošības gatavība

66%

Procenti ir kontroles gatavības novērtējums pēc koda, publiskās vides, procesa un pierādījumu stāvokļa. Tie nav sertifikācija, incidenta varbūtība vai juridisks atzinums.

Pārbaudīts pirms prezentācijas

Kontrole	Pierādītais rezultāts
Izlaidums	PR 73 apvienots pēc zaļas CI pārbaudes; publiski darbojas main SHA 664b5e58bde2fe39287b806c5606eb573a78c1ae.
Publiskā virsma	Galvenās lapas atbild ar 200; /api/health izdod tikai ok un build ar no store; publiskajā notikumu API nav iekšējo lauku.
Piekļuves robeža	Anonīms /api/center/health un POST /api/live-data/refresh saņem 401.
Atkopšana	Izmēģināta pāreja uz iepriekšējo SHA 6636f6f un atjaunošana uz 664b5e5; abas versijas publiski identificējās pareizi.
Pieejamība	Lietotne un Cloudflare Tunnel darbojas ieslēgtos systemd lietotāja servisos ar Restart always un pēc piespiedu procesa kļūmes atjaunojās automātiski.

Pašreizējā arhitektūra

Internets → Cloudflare proxy → Cloudflare Tunnel → lokāls izcelsmes servers → Vite priekšskatījuma serveris

Tunelis samazina tiešu servera ekspozīciju, bet neaizstāj WAF, hosta aizsardzību vai vairāku instanču pieejamību. Cloudflare Worker pastāv, taču nav publiskā domēna izcelsme.

Prezentācijas robežas

- Apzināti pieļaujams** kopīgā Centra parole, sintētiski dati un Vite priekšskatījuma serveris tikai marķētā demonstrācijas režīmā.
- Nedrīkst apgalvot** pilnu produkcijas gatavību, aktīvus pielāgotus Cloudflare WAF noteikumus, individuālu operatoru attiecināmību vai ISO sertifikāciju.

Izolēto aspektu drošības stāvoklis

Aspekts	Gatavība	Pierādīts tagad	Atlikušais darbs
Publiskā virsma	92%	Minimāls health, atļauto lauku DTO, anonīmās pārbaudes iziet.	Perimetra limiti un pārējo publisko DTO periodiska pārbaude.
Izlaidumi un atkopšana	90%	Precīzs SHA, nemaināmi laidieni, restartēšana un atgriešanās pārbaudīta.	Aizstāt Vite preview; ieviest otru izcelsmes instanci vai pārbaudītu Worker vidi.
MI un ārkārtas loģika	82%	Ārkārtas atbilde pirms MI; publicē tikai cilvēks; shēmas un avoti.	Promptu injekcijas red team, centrāla telemetrija un pakalpojuma izslēgšanas režīms.
Repozitorijs un piegādes ķēde	74%	CI, 32 pārbaudes, build, kritisku atkarību vārti, Dependabot un CODEOWNERS.	Main aizsardzība, drošības brīdinājumi un augsto vidējo atkarību sasniedzamības analīze.
Dati un Supabase	65%	Servera atslēgas, noturīga glabātuve, lauku minimizācija un validācija.	Datu karte, NIDA, glabāšana un dzēšana, minimālas DB lomas, audits un restore tests.
Identitāte un sesijas	58%	Droši sīkfaili, izcelsmes pārbaudes, iekšējā diagnostika aiz sesijas.	Individuāli konti, MFA, sesiju atsaukšana, ierīču kontrole un darbību attiecināmība.
Faili	55%	Privāta glabāšana, īpašnieka, izmēra un deklarētā tipa pārbaudes.	Karantīna, ļaunprogrammatūras skenēšana un droša satura pārkodēšana.
Cloudflare perimetrs	45%	Proxy un tunelis; lietotnes limiti; anonīms refresh ir slēgts.	R1 modeļu API un R3 login limiti, WAF un Security Events pārbaude.
Misijas un brīvprātīgie	45%	Cilvēka publicēšana, versēšana, idempotence un pamata audits.	Kompetenču un bīstamības vārti, četru acu princips, piekrišana un atsaukšana.
Monitorings un incidenti	55%	Minimāls health, uzraudzīti procesi un pārbaudīts rollback.	Uptime un ļaunprātīgas izmantošanas brīdinājumi, IR plāns, backup restore un galda mācības.

Svarīgākie atlikušā darba īpašnieki

- **Cloudflare zonas administrators līdz 2026 gada 17 septembrim** ieviest R1 modeļu API un R3 pieteikšanās Managed Challenge limitus, pēc tam septiņas dienas pārskatīt Security Events. Ja prezentācija ir agrāk, risks jānosauc un jāatstāj lietotnes limiti kā kompensējoša kontrole.
- **GitHub repozitorija administrators līdz 2026 gada 17 septembrim** aizsargāt main ar obligātu PR, verify un CODEOWNER apstiprinājumu; aizliegt piespiedu pārrakstīšanu un dzēšanu; ieslēgt pieejamos Dependabot un noslēpumu brīdinājumus.
- **Infrastrukturā īpašnieks līdz 2026 gada 10 oktobrim** aizstāt Vite priekšskatījuma serveri ar atbalstītu produkcijas izpildvidi vai pārbaudīt Worker migrāciju pirmsražošanas domēnā; pievienot uptime brīdinājumus.
- **Produkta privātuma un drošības īpašnieki pirms personas datu pilota** pabeigt datu karti un NIDA, individuālu identitāti un MFA, sesiju atsaukšanu, failu karantīnu, misiju drošības vārtus un rezerves kopiju atjaunošanas mācības.

Galvenie uzbrukuma ceļi API datu ieguve, pieprasījumu plūdi un izmaksu izsmelšana, sesiju zādzība, pikšķerēšana un kopīgi akreditācijas dati, promptu injekcija, ļaunprātīgi faili, ārējo avotu kompromitēšana, iekšēja kļūda un piegādes ķēdes risks.

Standartu ceļš VДАР; Nacionālā kiberdrošības likuma, NIS2 un MK noteikumu Nr 397 piemērojamības lēmums; Kiberneturības akts pa produktiem; MI akts pēc MI lomas; NIST CSF 2 un OWASP ASVS 5 kā ieviešanas ietvari. ISO 27001 tikai tad, kad to prasa tirgus vai iepirkums.